

ComplyAI Compliance Analysis Report

Client: IRS

Document: IRS.pdf

Generated: 2025-10-02 11:49:24

Processing Time: 83.07 seconds

Model Used: gpt-4o-mini

Executive Summary

EXECUTIVE SUMMARY - ComplyAI Analysis

Policy Statements Analyzed: 88

- Aligned: 8 (9.1%)
- Needs Improvement: 75 (85.2%)
- Non-compliant: 5 (5.7%)

Priority Items:

- High: 5
- Medium: 75
- Low: 8

Top Frameworks:

- ISO 27001: 39 matches
- CIS Controls v8: 32 matches
- NIST CSF: 9 matches

NEXT STEPS:

1. Address 5 high-priority gaps
2. Review 75 weak policies
3. Regular compliance monitoring recommended

Generated using gpt-4o-mini.

Detailed Policy Analysis

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	CIS Controls v8	None	Security, Privacy, Assurance and Artificial Intelligence Chapter 8.	All data must be managed throughout its entire lifecycle in accordance with privacy regulations, ensuring that information security is embedded in all information systems and services (CIS Controls v8-None, ISO 27001-None).
Weak	Medium	ISO 27001	None	Information Technology (IT) Security 10.8.11.	All employees must undergo regular security awareness and skills training to ensure compliance with ISO 27002:2013 and CIS Controls v8, thereby fostering a culture of information security throughout the organization.
Aligned	Low	CIS Controls v8	None	Application Security Policy Part 10.	
Weak	Medium	CIS Controls v8	None	Information Technology (IT) Security Section 11.	All employees must undergo regular security awareness and skills training to ensure compliance with established information security policies, as mandated by CIS Control 14.7 and ISO 27001 A.5.1.1.
Weak	Medium	ISO 27001	None	Application Security Policy 10.8.11 Application Security Policy Manual Transmittal September 19, 2024 Purpose (1) This transmits revised Internal Revenue Manual (IRM) 10.8.11, Information Technology (...)	The Application Security Policy shall be documented, approved, and regularly reviewed to ensure alignment with ISO 27001 standards and the commitment to continual improvement of the information security management system.
Weak	Medium	ISO 27001	None	The purpose of this IRM is to provide guidance and establish requirements necessary to implement and manage IT security for applications within the IRS.	This policy establishes requirements for implementing and managing IT security for IRS applications, ensuring alignment with organizational information security management system standards and achieving intended security outcomes (ISO 27001-None, ISO...
Weak	Medium	ISO 27001	None	Material Changes (1) Updated the Chief Information Officer.	Policy Statement: The Chief Information Officer shall ensure that all material changes, including updates on action statuses from management reviews and relevant internal/external issues, are communicated promptly to stakeholders, addressing any conf...
Missing	High	PCI DSS	None	(2) Removed Scope 10.8.11.1.1 and Objectives 10.8.11.1.1.2.	All enterprise assets must have unnecessary services uninstalled or disabled, and security personnel must reset access credentials immediately after first use to ensure compliance with PCI DSS and CIS Controls.
Weak	Medium	NIST CSF	IR-03	(3) IRM 10.8.11.1.4, Program Management and Review - Updated to align with IRM 1.11.2 requirements.	The organization shall implement robust mechanisms to protect technology assets from environmental threats and establish processes for assessing the authenticity and integrity of hardware and software, ensuring resilience and effective response to vu...

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	CIS Controls v8	None	(4) IRM 10.8.11.1.5, Program Control - Updated to align with IRM 1.11.2 requirements.	All system changes must undergo a formalized control process, ensuring risk assessment, documentation, and approval in accordance with CIS Critical Security Controls v8 and ISO 27001 standards A.14.2.2 and A.14.2.3.
Weak	Medium	ISO 27001	None	(5) IRM 10.8.11.2, IT Security Controls - Replaced the word shall with must throughout the IRM to align with IRM 1.11.2.	All information security policies must be defined, approved, and documented to ensure compliance with ISO 27001 controls, fostering a robust framework for information security management. (ISO 27001-None, ISO 27001-None)
Weak	Medium	ISO 27001	None	(8) Editorial changes made throughout the IRM for clarity and alignment with Security Policy Boilerplate 2 July 2024.	The IRM has been updated for clarity and compliance with Security Policy Boilerplate as of July 2024, incorporating insights from previous management reviews and aligning with the latest PCI DSS v2.0 and ISO 27001 standards.
Weak	Medium	ISO 27001	None	Reviewed and updated plain language, grammar, titles, website addresses, legal references and IRM references.	The policy will be regularly reviewed and updated to ensure compliance with all relevant legislative, statutory, regulatory, and contractual requirements, as outlined in ISO 27001, while maintaining clear and accessible documentation.
Aligned	Low	ISO 27001	None	Effect on Other Documents This IRM supplements IRM 10.8.1, Information Technology (IT) Security Policy and Guidance; IRM 10.8.2, Information Technology (IT) Security, IT Security Roles and Responsibil...	
Weak	Medium	PCI DSS	None	IRM 10.8.11, dated November 3, 2023 is superseded.	All information processing systems must comply with the updated PCI DSS v4.0 requirements and ISO 27001-A.18 standards to ensure the integrity and availability of sensitive data.
Weak	Medium	ISO 27001	None	Audience IRM 10.8.11 must be distributed to all personnel responsible for overseeing, managing, and implementing application security for IRS information and information systems.	All personnel overseeing, managing, and implementing application security for IRS information and systems must receive and acknowledge Audience IRM 10.8.11, and are required to promptly report any observed or suspected information security weaknesses...
Weak	Medium	ISO 27001	None	The Application Security Policy IRM will consist of, but will not be limited to, agency defined requirements, authoritative guidance, legislative mandates, and national standards.	The Application Security Policy will encompass agency-defined requirements, authoritative guidance, legislative mandates, and national standards, while ensuring that all new information systems and enhancements incorporate information security requir...
Weak	Medium	ISO 27001	None	This policy applies to all employees, contractors, and vendors of the IRS.	All employees, contractors, and vendors of the IRS are required to adhere to information security policies and contractual agreements throughout their engagement, ensuring compliance with established security protocols (ISO 27001 A.7.1.2, A.7.2).

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	ISO 27001	None	This policy is subordinate to IRM 10.8.1, Information Technology (IT) Security, Policy and Guidance, and augments the existing requirements identified within IRM 10.8.1, as they relate to IRS applicat...	This policy enhances IRM 10.8.1 by mandating the integration of information security requirements into the development of IRS applications, including a Statement of Applicability that justifies the inclusion or exclusion of necessary controls (ISO 27...
Weak	Medium	ISO 27001	None	(2) Purpose of the Program: Develop and publish security policies to protect the IRS against potential IT threats and vulnerabilities and ensure compliance with federal mandates and legislation.	The program aims to establish and maintain comprehensive security policies that effectively mitigate IT threats, ensure compliance with federal mandates, and achieve defined information security objectives as outlined in ISO 27001, while continuously...
Weak	Medium	ISO 27001	None	(3) Audience: The provisions within this policy apply to: a.	This policy applies to all personnel and stakeholders, mandating the establishment, documentation, and regular review of an access control policy that aligns with business needs and information security requirements, as outlined in ISO 27001 Control ...
Weak	Medium	ISO 27001	None	All offices and business, operating, and functional units within the IRS.	All IRS offices and operational units must identify and document their organizational assets, assigning clear protection responsibilities to ensure compliance with ISO 27001:2013 Control A.8.1.1 and PCI DSS standards for safeguarding sensitive inform...
Weak	Medium	ISO 27001	None	b. IRS personnel and organizations having contractual arrangements with the IRS, including employees, contractors, vendors, and outsourcing providers, that use or operate systems that store, process, ...	All IRS personnel, contractors, vendors, and outsourcing providers must adhere to documented information security protocols and objectives that govern the handling of IRS information, ensuring secure interfaces and dependencies with external systems ...
Weak	Medium	ISO 27001	None	(4) Policy Owner: Chief Information Officer (5) Program Owner: Cybersecurity, Cybersecurity Threat Response and Remediation (6) Program Goals: To protect the confidentiality, integrity, and availabili...	The Chief Information Officer shall ensure that documented information security objectives are established, maintained, and periodically reviewed to enhance the confidentiality, integrity, and availability of IRS information and systems, in accordanc...
Weak	Medium	CIS Controls v8	None	An application is a software program that is hosted by an information system and is designed to perform a specific function directly for the user or, in some cases, for another application.	An application is a software asset hosted on enterprise systems designed to perform specific functions for users or other applications, encompassing web, database, cloud-based, and mobile platforms (CIS Controls v8-None).
Weak	Medium	ISO 27001	None	Application programs can be executed without access to system control, monitoring, or administrative privileges.	Policy Statement: Application programs must be executed with appropriate access controls, ensuring that system control, monitoring, and administrative privileges are restricted to authorized personnel only, in compliance with ISO 27001 and CIS Contro...

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	ISO 27001	None	(2) IRM 10.8.11 is part of the Security, Privacy, and Assurance policy family, IRM Part 10 Series for IRS IT Cybersecurity.	The IRS IT Cybersecurity policy, as outlined in IRM 10.8.11, establishes a comprehensive framework for information security that is defined, approved, and regularly reviewed to ensure alignment with ISO 27001:2013 standards for effective risk managem...
Aligned	Low	SOC 2	None	This framework of security controls is provided through the issuance of security policies via the IRM 10.8 series and the development of technology specific security requirements checklists.	
Weak	Medium	NIST CSF	None	Stakeholders are notified when revisions to the security policies and security requirements checklists are made.	Revisions to security policies and requirements checklists will be communicated to stakeholders promptly, ensuring alignment with ongoing risk management assessments and adherence to commitments related to security and availability (NIST CSF, SOC 2).
Weak	Medium	ISO 27001	None	(2) It is the policy of the IRS to: a.	The IRS is committed to establishing and maintaining an information security management system that aligns with ISO 27001 standards, ensuring the fulfillment of applicable requirements and continuous improvement of information security objectives.
Aligned	Low	ISO 27001	None	Establish and manage an information security program within its organizations.	
Weak	Medium	NIST CSF	None	This policy provides uniform policies and guidance to be used by each organization.	Revised Policy: This policy establishes a comprehensive, organization-wide framework for formal approval and communication of risk management and cybersecurity practices, ensuring consistent and effective handling of cybersecurity risks across all le...
Weak	Medium	NIST CSF	None	Protect all IT resources belonging to, or used by, the IRS at a level commensurate with the risk and magnitude of harm that could result from loss, misuse, or unauthorized access to that IT resource.	All IT resources of the IRS shall be secured based on a comprehensive risk assessment, ensuring protection against loss, misuse, or unauthorized access while enhancing the organization's resilience to cybersecurity events and enabling the pursuit of ...
Weak	Medium	ISO 27001	None	c. Protect its information resources and allow the use, access, disposition, and disclosure of information in accordance with applicable laws, policies, federal regulations, OMB guidance, Treasury Dir...	The organization will safeguard its information resources by ensuring their use, access, disposition, and disclosure comply with applicable laws and regulations, while regularly assessing and updating security measures based on risk assessments and i...
Weak	Medium	ISO 27001	None	d. Use best practices methodologies (such as Capability Maturity Model Integration (CMMI), enterprise lifecycle (ELC), Information Technology Infrastructure Library (ITIL), and Lean Six Sigma (LSS)) t...	Incorporate best practices methodologies (CMMI, ELC, ITIL, LSS) to enhance IRS IT processes and services, ensuring seamless integration with the information security management system and alignment with broader risk management frameworks (ISO 27001, ...

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	ISO 27001	None	The IRM authors continuously monitor federal guidance (e.g., OMB, CISA, NIST, DISA) for potential revisions to security policies and security requirements checklists.	The IRM authors will review and update security policies and requirements checklists annually, or upon significant organizational changes, to ensure alignment with federal guidance and compliance with ISO 27001 and CIS Controls.
Weak	Medium	ISO 27001	None	Revisions to security policies and checklists are reviewed by the security policy team, in collaboration with applicable stakeholders, for potential impact to the IRS operational environment.	Revisions to security policies and checklists shall be systematically reviewed at planned intervals or upon significant changes, ensuring ongoing compliance and alignment with ISO 27001 standards, while actively engaging relevant stakeholders to asse...
Aligned	Low	ISO 27001	None	(2) Security Policy provides a weekly report identifying security policies and security requirements checklists that have recently been revised or are in the process of being revised.	
Weak	Medium	NIST CSF	IR-03	(3) This IRM applies to all IRS information and information systems, which include IRS production, development, test, and contractor systems.	This IRM encompasses all IRS information and information systems, including production, development, test, and contractor systems, ensuring protection against environmental threats and resilience in both normal and adverse situations as per NIST CSF-...
Weak	Medium	SOC 2	None	For systems that store, process, or transmit classified national security information, refer to IRM 10.9.1, Classified National Security Information (CNSI), for additional guidance for protecting clas...	All systems that store, process, or transmit classified national security information must implement stringent access controls and data protection measures in accordance with SOC 2 and CIS Controls v8 to safeguard against unauthorized access, use, an...
Weak	Medium	ISO 27001	None	(4) This IRM establishes the minimum baseline security policy and requirements for all IRS applications IT assets in order to: a.	This IRM mandates that all IRS applications and IT assets adhere to the organization's information security management system and ISO 27001 standards, ensuring comprehensive identification, documentation, and regular review of security requirements i...
Weak	Medium	NIST CSF	None	Protect the critical infrastructure and assets of the IRS against attacks that exploit IRS assets.	Revised Policy: Ensure the protection of IRS critical infrastructure and assets by implementing robust security measures to mitigate risks and enhance resilience against cybersecurity threats, while also leveraging opportunities for improvement (NIST...
Weak	Medium	CIS Controls v8	None	Prevent unauthorized access to IRS assets.	To prevent unauthorized access to IRS assets, we will implement an automated process to immediately disable user accounts and revoke access rights upon termination, role changes, or rights revocation, in accordance with CIS Controls v8-None.
Aligned	Low	ISO 27001	None	c. Enable IRS IT computing environments to meet the security requirements of this policy and support the business needs of the organization.	

Status	Priority	Framework	Control ID	Policy Statement	Suggested Improvement
Weak	Medium	PCI DSS	None	Note: IRM 10.8.1 applies to on-premises systems, including on-premises cloud models.	All systems, including on-premises and cloud models, must ensure that Management Protocol (SNMP) defaults are secured and that resilience mechanisms are implemented to maintain availability and capacity in both normal and adverse situations (PCI DSS-...
Aligned	Low	CIS Controls v8	None	For off-premises cloud models, refer to IRM 10.8.24, Information Technology (IT) Security, Cloud Computing Security Policy.	
Weak	Medium	ISO 27001	None	(5) In the event there is a discrepancy between this policy and IRM 10.8.1, IRM 10.8.1 has precedence, unless the security controls/requirements in this policy are more restrictive.	In the event of a discrepancy between this policy and IRM 10.8.1, this policy shall take precedence if it establishes more stringent security controls, in alignment with ISO 27001 A.5.1.1 and A.5.1.
Missing	High	NIST CSF	None	===== (2) =====	All personnel must adhere to established compliance protocols and regularly participate in training to ensure understanding and implementation of the NIST Cybersecurity Framework (CSF) standards, as outlined in NIST CSWP Appendix B and C.
Weak	Medium	ISO 27001	None	AO Authorizing Official Contractors are individuals or other legal entities that are, directly or Contractor indirectly, awarded government contracts.	All contractors authorized by the AO must have documented agreements that clearly define their access to organizational assets and security responsibilities, in compliance with ISO 27001 A.15.1.2 and PCI DSS requirements.
Weak	Medium	ISO 27001	None	Contractors conduct business, or reasonably may be expected to conduct business, with the Government as an agent or representative of another contractor.	All contractors must adhere to established information security responsibilities outlined in their contractual agreements, including a risk assessment of their services and potential impact on the organization, as per ISO 27001 and CIS Controls v8.
...	...	...	...	... and 38 more items	See JSON report for complete details